

Propuesta de seguridad y validaciones

Pantalla de Registro Único de Contribuyentes — persona física y persona moral

Alcance Frontend, backend, QA y cumplimiento	Total de tareas 29	Estado Documento de trabajo
--	--------------------	-----------------------------

1. Resumen

La pantalla actual de alta solicita RFC, CURP, nombre, correo y teléfono sin control anti-bot, sin consentimiento de tratamiento de datos personales y sin verificación de identidad contra fuente autoritativa. En un padrón fiscal esto habilita tres riesgos concretos: registro masivo automatizado, enumeración del padrón mediante prueba de RFC, y suplantación de contribuyentes mediante datos de terceros.

Esta propuesta cubre esos huecos con veintinueve tareas agrupadas en diez temas. El criterio de agrupación es la **dependencia cruzada**: cada tarea de backend aparece junto a su contraparte de frontend, porque implementar una sin la otra deja el control incompleto y genera una falsa sensación de cobertura.

2. Hallazgos que originan la propuesta

Hallazgo	Riesgo asociado
No existe consentimiento ni Aviso de Privacidad	Incumplimiento LFPDPPP al recabar RFC y CURP
Sin control anti-bot	Registro masivo, enumeración de RFC, fraude de tarificación por SMS
Clave lada "52" fija	Excluye a residentes en el extranjero
CURP opcional y sin verificación	Se pierde el mecanismo de identidad más fuerte disponible
Persona moral sin representante legal	Cualquiera puede registrar un RFC moral ajeno
Código de acceso sin controles definidos	Es la autenticación completa del sistema

3. Flujo objetivo del alta

1	Rate limit y verificación de Turnstile
2	Validación estructural: RFC, CURP, nombres, correo, teléfono
3	Coherencia RFC ↔ CURP (persona física)
4	Verificación de CURP ante RENAPO / SUMA
5	Validación de RFC contra fuente autoritativa
6	Alta en estado PENDIENTE y envío del código de acceso
7	Respuesta genérica de latencia constante

Los pasos 4 y 5 se ejecutan **exclusivamente en el servidor**. Exponer credenciales de RENAPO o de un PAC en el navegador convierte el formulario público en un oráculo de consulta del padrón nacional.

4. Listado de tareas

La columna **Par** indica la tarea recíproca. Los identificadores son estables y pueden usarse tal cual al levantar las tareas en Zoho.

4.1. Validación de datos

ID	Tarea	Par	Descripción
FE-01	Validaciones de campos en formulario	BE-01, BE-02	Validación on-blur de RFC (13 física / 12 moral), CURP (18), nombres y apellidos (letras, acentos, Ñ, apóstrofo, guion), razón social (máx. 250), correo y teléfono. Autoconversión a mayúsculas y trim en RFC/CURP. Mensajes específicos por campo, no genéricos. Nunca bloquear pegado ni gestores de contraseñas. Es solo UX: la fuente de verdad es el backend.
FE-10	Manejo de severidades block vs review	BE-01, BE-02	El backend devuelve hallazgos con severidad. block se muestra como error e impide el envío. review no se muestra al usuario ni frena el flujo: el registro procede y queda marcado para revisión humana. Definir el contrato de la respuesta de error para que el front no filtre por accidente hallazgos internos.
BE-01	Módulo de validación estructural server-side	FE-01	RFC física/moral: regex, longitud, fecha embebida, RFC genéricos, palabras inconvenientes, dígito verificador módulo 11. CURP: catálogo de entidades, consonantes internas, fecha real, dígito verificador. Nombres, razón social, correo y teléfono en E.164. Detección de homógrafos cirílicos y griegos. Sistema de severidades block/review. Repite toda validación del frontend.
BE-02	Coherencia RFC ↔ CURP	FE-01	Validar que RFC[0..9] == CURP[0..9] en persona física. Manejar la excepción de palabras inconvenientes (SAT y RENAPO aplican reglas distintas) marcando review en lugar de rechazo automático. Es la validación cruzada de mayor valor del sistema.
BE-13	Carga y mantenimiento de catálogos	FE-05	Catálogo vigente de claves lada del IFT, entidades federativas de CURP y palabras inconvenientes del SAT. Definir proceso de actualización periódica y exponerlos al front donde aplique.

4.2. Verificación de identidad contra fuentes autoritativas

ID	Tarea	Par	Descripción
FE-08	Estados de verificación de CURP	BE-04	Indicador de "verificando" no bloqueante al salir del campo. Resolver cuatro escenarios: válida → check discreto; no coincide → pedir revisar datos sin revelar cuáles difieren; servicio no disponible → permitir continuar en PENDIENTE_VERIFICACION, nunca bloquear el alta; baja → mensaje neutro con canal presencial. El botón "Crear cuenta" no debe quedar deshabilitado esperando respuesta. Prohibido autocompletar o mostrar nombre, sexo o fecha devueltos por RENAPO : convertiría el formulario en un oráculo CURP → identidad. Al front solo viaja un veredicto.
FE-11	Campos adicionales de persona moral	BE-05	Agregar representante legal (nombre y RFC) y, según la ruta elegida en BE-05, carga de e.firma o de Constancia de Situación Fiscal. Hoy cualquiera puede registrar un RFC moral ajeno. Incluye validación de tipo y peso de archivo, y estados de carga.
BE-04	Integración RENAPO / SUMA para validar CURP	FE-08	Confirmar contrato, autenticación, cuotas y SLA con el área del convenio. Cliente con mTLS, timeout 2-3 s, reintento único con backoff y circuit breaker que degrade a PENDIENTE_VERIFICACION. Comparar nombres devueltos contra los capturados con Jaro-Winkler o Levenshtein y umbral, en el servidor . Manejar explícitamente baja por defunción . Caché sobre CURP hasheada con HMAC y pepper, TTL corto. La respuesta al front es solo el veredicto.
BE-05	Validación de RFC contra fuente autoritativa	FE-11	Persona física: apoyarse en la coherencia con CURP ya validada (BE-02). Persona moral: evaluar y contratar API de PAC o exigir e.firma del representante legal. Montar espejo local del listado de RFC del SAT para CFDI 4.0 como primer filtro, más conciliación por lotes. Investigar convenio de intercambio con el SAT a mediano plazo.

4.3. Anti-bot y anti-abuso

ID	Tarea	Par	Descripción
FE-02	Integrar widget Cloudflare Turnstile	BE-03	Widget invisible al montar el formulario con data-action="registro-contribuyente". Botón "Crear cuenta" deshabilitado hasta recibir token. Callbacks de error y expiración con turnstile.reset(). Enviar token en alta, reenvío de código y canje de OTP.
BE-03	Verificación Turnstile server-side	FE-02	Llamada a siteverify validando success, hostname esperado, action y antigüedad de challenge_ts (menor a 300 s). Secret únicamente en gestor de secretos. Aplicar en los tres endpoints. Política de degradación documentada si el servicio no responde.
BE-07	Rate limiting y anti-abuso	FE-07	Límites escalonados por IP, rango de IP, RFC, correo y teléfono. Protección específica del endpoint de reenvío contra fraude de tarificación por SMS. Campo honeypot y medición de tiempo de llenado (menor a 2 s = bot). WAF frente a los endpoints de registro y canje.

4.4. Código de acceso (OTP)

ID	Tarea	Par	Descripción
FE-06	Pantalla de canje de código	BE-06	Input segmentado de 6 dígitos, contador regresivo de vigencia, botón de reenvío con cooldown de 60 s, manejo de intentos agotados y mensaje genérico de éxito.
BE-06	Servicio de código de acceso	FE-06	Generación con crypto.randomInt (6 dígitos), vigencia 10 min, un solo uso. Almacenamiento hasheado con Argon2id o HMAC con pepper, nunca en claro ni en logs. Máximo 5 intentos, comparación con timingSafeEqual. Vinculación a session_id y user_agent. Cooldown de reenvío 60 s, tope 3 por hora y 10 por día por destinatario.

4.5. Anti-enumeración del padrón

ID	Tarea	Par	Descripción
FE-09	Respuesta genérica en pantalla de éxito	BE-08	Mensaje idéntico exista o no el RFC: "Si los datos son correctos, enviaremos un código de acceso a tu correo". Prohibido mostrar "esta cuenta ya existe" o variantes. Aplica también a la analítica del front, que no debe emitir eventos distintos por caso.
BE-08	Respuesta y latencia constantes	FE-09	HTTP 202 con mensaje genérico en todos los casos. Igualar latencia con piso constante (aprox. 800 ms) para no filtrar existencia por tiempo de respuesta. El aviso de "ya tienes cuenta" se envía por correo al titular, nunca por pantalla.

4.6. Orquestación del flujo de alta

ID	Tarea	Par	Descripción
FE-07	Estados de carga, idempotencia y errores HTTP	BE-07, BE-09	Botón con spinner y bloqueo durante el envío. Generar y enviar idempotency-key para evitar duplicados por doble clic o reintento de red. Manejo explícito de HTTP 429 con mensaje de espera y respeto al encabezado Retry-After.
BE-09	Endpoint orquestador /registro	FE-07	Flujo completo: rate limit → Turnstile → validación estructural → coherencia → RENAPO → validación RFC → alta en PENDIENTE → envío de OTP → respuesta genérica. Soporte de idempotency-key. Consultas parametrizadas y validación por lista de permitidos.

4.7. Privacidad, consentimiento y protección de PII

ID	Tarea	Par	Descripción
FE-04	Consentimiento y Aviso de Privacidad	BE-12	Checkbox obligatorio no premarcado con enlaces a Aviso de Privacidad y Términos. Debe mencionar explícitamente la verificación de CURP ante RENAPO. Bloquear el envío si no está marcado.
FE-13	Higiene de PII en el cliente	BE-11	Prohibido enviar RFC, CURP, nombre, correo o teléfono a herramientas de analítica o monitoreo de errores. Sin PII en URLs, query strings, localStorage o sessionStorage. Enmascarar campos sensibles en grabaciones de sesión si existen. autocomplete="off" en el campo de OTP.
BE-11	Protección de PII y bitácora de auditoría	FE-13	Cifrado en reposo de RFC y CURP, evaluar tokenización. Bitácora con IP, user-agent, timestamp y hash del identificador; prohibido registrar PII en claro en logs o telemetría. Política de retención definida.
BE-12	Evidencia de consentimiento y derechos ARCO	FE-04	Persistir versión del Aviso, hash del documento, timestamp e IP al momento de aceptar. Implementar mecanismo de atención de derechos ARCO.

4.8. Endurecimiento de plataforma

ID	Tarea	Par	Descripción
FE-12	Compatibilidad del front con CSP estricta	BE-10	Eliminar scripts y estilos inline; migrar a nonce. Verificar que el widget de Turnstile funcione con la CSP (requiere challenges.cloudflare.com en script-src y frame-src). Enviar token anti-CSRF en cada request del flujo.
BE-10	Cabeceras y configuración de seguridad	FE-12	CSP con nonce sin unsafe-inline, HSTS con preload, X-Content-Type-Options, X-Frame-Options DENY, Referrer-Policy, Permissions-Policy y Cache-Control no-store en todo el flujo. Token anti-CSRF y cookies HttpOnly, Secure, SameSite Strict. TLS 1.3.

4.9. Accesibilidad y UX del formulario

ID	Tarea	Par	Descripción
FE-03	Accesibilidad y presentación de errores	—	autocomplete, inputmode, aria-invalid y aria-describedby en cada input. Resumen de errores enfocable al enviar. Contraste, navegación por teclado y etiquetas asociadas correctamente.
FE-05	Selector de país y lada	BE-13	Reemplazar el "52" fijo por un selector de país real para permitir el registro de residentes en el extranjero. Formateo visual del número según el país. Consume el catálogo de BE-13.

4.1. QA y seguridad

ID	Tarea	Par	Descripción
QA-01	Corpus de pruebas de dígitos verificadores	BE-01	Armar corpus de RFC y CURP reales conocidos y validar ambos algoritmos. Bloqueante: hasta completarse, el dígito verificador del RFC debe permanecer en severidad review, no block.
QA-02	Pruebas de penetración y revisión de código	Todas	Pentest del flujo de registro con foco en enumeración, bypass de Turnstile, abuso de OTP, inyección y fuga de datos vía la respuesta de RENAPO. Revisión de código por el equipo de seguridad.
QA-03	Validación jurídica del tratamiento de datos	FE-04, BE-11, BE-12	Revisión por el área legal del Aviso de Privacidad, finalidades declaradas, principio de minimización y cumplimiento LFPDPPP antes del despliegue.

5. Pares que no deben separarse en sprints distintos

Implementar uno sin el otro deja un hueco de seguridad activo en producción.

Par	Motivo
FE-08 ↔ BE-04	Sin el manejo de estados en el front, la verificación de CURP bloquea altas legítimas cuando el servicio se degrada, o filtra identidad si se autocompletan los datos devueltos.
FE-09 ↔ BE-08	Si la pantalla distingue entre cuenta existente y nueva, la latencia constante del backend no sirve de nada: el padrón queda enumerable.
FE-02 ↔ BE-03	Un token que nadie verifica en el servidor es decorativo; una verificación sin widget rechaza todo el tráfico legítimo.
FE-12 ↔ BE-10	Publicar la CSP estricta antes de limpiar los inline scripts rompe el formulario en producción.

6. Distribución

Frontend	Backend	QA y seguridad	Total
13	13	3	29

7. Advertencias sobre el contenido

Dígitos verificadores sin verificar. El algoritmo del dígito verificador del RFC (módulo 11) tiene variantes en la literatura pública y no fue contrastado contra RFC reales. Debe permanecer en severidad **review** hasta completar QA-01. El de CURP requiere la misma prueba.

Referencias externas. Las menciones a servicios del SAT, RENAPO, proveedores autorizados de certificación y al servicio SUMA provienen de conocimiento general y no fueron verificadas contra documentación vigente. Confírmense directamente con cada proveedor antes de usarlas en un contrato, una licitación o un análisis de mercado.

Responsabilidad. Este documento contiene sugerencias técnicas generadas con apoyo de inteligencia artificial. No constituye una auditoría de seguridad ni asesoría jurídica. La priorización, la validación técnica y la decisión final de arquitectura corresponden al equipo humano responsable. Antes del despliegue en producción se requiere revisión de código, pruebas de penetración y validación jurídica del tratamiento de datos personales conforme a la normatividad mexicana vigente.